

Institut Nationale des Sciences Appliquées

Filière : Sécurité et Technologie de l'Informatique
(STI-5A)

Année Académique : 2024-2025

République de la France

Liberté, Egalité, Fraternité



INSTITUT NATIONAL
DES SCIENCES
APPLIQUÉES
CENTRE VAL DE LOIRE

Cybersecurity assisted by IA

Vulnerability Analysis

Réalisé par :

NGUYEN Ke An

NGUYEN Ngoc Khanh Hoai

OUJGHI Nouhaila

PEZONGO Mickael

Nom du Professeur :

MR Laurent BOBELIN

I. Introduction

Dans un monde de plus en plus interconnecté, la cybersécurité est devenue une priorité majeure pour les organisations. La détection des vulnérabilités, qu'elles soient dans le code source ou au sein des infrastructures réseau, est un élément clé pour prévenir les cyberattaques. Ce projet vise à proposer une solution innovante et performante pour l'analyse des vulnérabilités, en s'appuyant sur l'intelligence artificielle (IA), et plus particulièrement sur les modèles de traitement du langage naturel tels que GPT.

L'objectif principal de cette solution est de combiner des outils traditionnels d'analyse avec les capacités avancées d'IA pour détecter, documenter et fournir des recommandations exploitables face aux vulnérabilités identifiées. En intégrant des fonctionnalités interactives et automatisées, ce projet offre une approche adaptée aux développeurs, aux équipes de sécurité, et aux gestionnaires IT.

II. Contexte général sur l'analyse de vulnérabilités assistée par IA

A. Avantages

L'utilisation de l'intelligence artificielle pour l'analyse des vulnérabilités présente de nombreux avantages, notamment l'automatisation, qui réduit le temps nécessaire pour détecter et analyser les failles grâce à une inspection rapide et précise. Elle offre également des recommandations personnalisées en proposant des explications détaillées et des solutions adaptées à chaque vulnérabilité détectée. De plus, l'IA se distingue par son adaptabilité, avec la possibilité d'entraîner et d'ajuster les modèles pour couvrir une grande variété de scénarios et de configurations. Enfin, elle simplifie la documentation en générant automatiquement des rapports clairs et exploitables, favorisant ainsi une meilleure collaboration entre les équipes.

B. Inconvénients

Cependant, l'intégration de l'intelligence artificielle dans l'analyse de vulnérabilités présente certaines limites, notamment une dépendance aux données, la précision des analyses reposant sur la qualité des données d'entraînement et des informations disponibles. De plus, l'utilisation de services basés sur l'IA, tels que GPT, peut engendrer des coûts liés à l'accès aux API et à l'infrastructure nécessaire. Enfin, la complexité technique de ces solutions exige des compétences avancées pour leur implémentation et leur maintenance.

C. Définitions des termes clés

Une vulnérabilité est une faille ou une faiblesse dans un système informatique pouvant être exploitée pour compromettre sa sécurité. L'analyse de vulnérabilités consiste à identifier, évaluer et documenter ces faiblesses potentielles afin de renforcer la protection des systèmes. L'intelligence artificielle (IA), domaine de l'informatique visant à simuler les capacités cognitives humaines telles que l'apprentissage et le raisonnement, joue un rôle clé dans ce processus, notamment grâce à des modèles avancés comme GPT (Generative Pre-trained Transformer), développés par OpenAI, qui permettent de comprendre, analyser et générer du texte en fonction des instructions reçues.

D. Nécessité de l'analyse de vulnérabilité par IA

Face à l'augmentation des cyberattaques et à la complexité croissante des environnements informatiques, les approches traditionnelles d'analyse des vulnérabilités montrent leurs limites. L'intelligence artificielle apporte une solution en offrant une analyse contextuelle approfondie, une adaptation rapide aux évolutions du code et des configurations, ainsi qu'un gain de temps considérable pour les équipes. En réponse aux défis modernes de la cybersécurité, l'analyse assistée par IA améliore la qualité et la sécurité des systèmes. Ce projet s'inscrit dans cette démarche en proposant une solution innovante et complète.

III. Les différentes méthodes d'analyse de vulnérabilités

L'analyse de vulnérabilités assistée par l'IA ouvre de nouvelles perspectives pour la cybersécurité, en permettant de traiter des menaces de manière plus rapide, plus précise et plus contextualisée. Voici un survol des principales méthodes d'analyse de vulnérabilités basées sur l'IA, ainsi que des exemples d'outils et techniques employés dans ces différents domaines.

- **Analyse de code assistée par l'IA** : Détecte les vulnérabilités du code (ex: SQL Injection) avec DeepCode et Codex.
- **Analyse des infrastructures réseau** : Identifie les failles réseau en scannant les configurations avec Darktrace et Nmap IA.
- **Analyse des applications web** : Repère les failles (XSS, SQLi) dans les sites et API avec Acunetix et Wallarm.
- **Analyse des journaux et anomalies** : Analyse les logs pour détecter les attaques avec Splunk et ELK Stack.
- **Analyse comportementale et prédictive** : Anticipe les menaces via l'analyse des comportements avec Exabeam et Vectra AI.

IV. L'analyse de code source assistée par IA

Pour l'analyse de code, plusieurs outils d'analyse de code existent chacun avec ses propres paramètres et spécificités. L'objectif de notre outil est de détecter et documenter les vulnérabilités potentielles dans le code source, tout en fournissant des recommandations précises pour les corriger. Cette solution combine l'utilisation d'un analyseur de répertoire, d'un service OpenAI (GPT), et de méthodes interactives pour afficher les résultats.

A. Description de la Solution

La solution repose sur une architecture bien définie. Elle commence par le scan des fichiers dans un répertoire donné ou d'un fichier unique, avec la possibilité de filtrer les extensions spécifiques. Ensuite, un service d'analyse, basé sur l'API GPT, est utilisé pour examiner le contenu du code source et détecter les vulnérabilités. Les résultats sont ensuite présentés de manière claire et interactive, permettant une compréhension rapide et des actions ciblées.

En termes de fonctionnalités principales, la solution analyse le code source en profondeur, générant des rapports détaillés pour chaque vulnérabilité détectée. Ces rapports incluent le type de vulnérabilité, la ligne affectée, une description concise, le code CWE associé, une recommandation de correction, ainsi que le niveau de gravité (faible, modéré, élevé, critique). L'analyse est flexible grâce à la possibilité de traiter des fichiers individuels ou des répertoires entiers.

B. Fonctionnement Technique

Le cœur de la solution est la classe **ChatGptService**, qui encapsule le service d'analyse fourni par GPT. Elle envoie le contenu du code source à l'API OpenAI et reçoit une réponse structurée en JSON. Par exemple, une réponse JSON typique comprend les détails des vulnérabilités détectées, comme le type, la ligne, une description, le code CWE, une recommandation et le niveau de gravité.

Les messages envoyés à l'API sont soigneusement construits pour inclure des consignes précises sur l'analyse attendue. Le modèle utilisé dans cet outil est "gpt-4o"

Les résultats sont présentés sous forme de tableaux clairs et intuitifs, formatés avec **tabulate**. Chaque type de vulnérabilité et niveau de gravité est mis en évidence grâce à un système de couleurs. Les vulnérabilités critiques apparaissent en rouge, les niveaux élevés en jaune, et les niveaux faibles en vert. Le texte est automatiquement ajusté pour éviter tout débordement visuel.

Pour améliorer les performances, la solution utilise asyncio, permettant de paralléliser les analyses de fichiers. Cela accélère les opérations, même sur des projets contenant un grand nombre de fichiers.

C. Commandes Disponibles

La solution propose des commandes flexibles pour s'adapter aux besoins des utilisateurs. Les arguments incluent **-d** ou **--directory** pour spécifier un répertoire complet à analyser, **-f** ou **--file** pour analyser un fichier unique, et **-x** ou **--extensions** pour filtrer les fichiers par extensions. Par exemple, une commande pour analyser un répertoire complet avec des fichiers .py et .js serait :

\$python codeScanner.py -d ./mon_projet -x .py .js

Pour analyser un fichier unique, une commande typique serait :

\$python codeScanner.py -f app.py

```

mick@DESKTOP-00RKS63: /mnt/c/PC/insa/SA_SA_IA/cybersecurity assisted by AI/project/code analysis$ python3 codeScanner.py -d ../ -x .py .js

```

Analyse du fichier : ../code analysis/codeScanner.py						
Fichier	Type	Ligne	Gravité	Code OME	Description	Recommandation
../code analysis/codeScanner.py	Utilisation de clés API en clair	10	élevé	OME-798	La clé API est chargée directement depuis les variables d'environnement sans validation ni chiffrement.	Utiliser un gestionnaire de secrets pour stocker et accéder aux clés API de manière sécurisée.
../code analysis/codeScanner.py	Injection de commande	64	critique	OME-78	La fonction 'os.walk' est utilisée pour lire les fichiers sans validation des entrées, ce qui peut permettre une injection de commande.	Valider et assainir toutes les entrées utilisateur avant de les utiliser dans des commandes système.

Analyse du fichier : ../code analysis/vuln_code.js						
Fichier	Type	Ligne	Gravité	Code OME	Description	Recommandation
../code analysis/vuln_code.js	Injection SQL	23	critique	OME-89	Utilisation directe des entrées utilisateur dans une requête SQL, ce qui permet des injections SQL.	Utiliser des requêtes préparées ou des procédures stockées pour éviter les injections SQL.
../code analysis/vuln_code.js	Cross-Site Scripting (XSS)	34	élevé	OME-79	Sortie non échappée permettant des attaques XSS.	Échapper correctement les données de sortie pour éviter les attaques XSS.
../code analysis/vuln_code.js	Téléchargement de fichiers non sécurisé	41	élevé	OME-434	Pas de vérification du type de fichier lors du téléchargement, ce qui peut permettre l'exécution de fichiers malveillants.	Vérifier le type de fichier et utiliser des listes blanches pour les types de fichiers autorisés.
../code analysis/vuln_code.js	Gestion de session non sécurisée	50	critique	OME-384	Aucune validation de la session, ce qui peut permettre des accès non autorisés.	Utiliser des mécanismes de gestion de session sécurisés et valider les sessions de manière appropriée.

Le code source est accessible sur le lien github suivant:

<https://github.com/mpezongo/code-vulnerability-analysis/>

Cette solution d'analyse de code assistée par IA offre une méthode efficace et intuitive pour identifier les vulnérabilités dans le code source. Grâce à son interface claire, son fonctionnement asynchrone, et sa personnalisation visuelle, elle constitue un outil puissant pour les développeurs et les équipes de sécurité. En intégrant les meilleures pratiques de sécurité, cette solution pourrait contribuer à renforcer la qualité et la fiabilité des projets logiciels.

L'analyse de réseaux

L'analyse de réseaux est une étape importante pour identifier les vulnérabilités potentielles dans les systèmes informatiques, en particulier celles liées aux services exposés et aux ports ouverts. Elle permet d'anticiper les attaques et en corrigeant les faiblesses identifiées.

V. L'Analyse des application Web

Cette partie présente le développement et l'exécution d'un outil DAST (Dynamic Application Security Testing) permettant de détecter automatiquement ces vulnérabilités. L'outil explore l'application cible, injecte des charges utiles malveillantes, analyse les réponses du serveur et génère un rapport détaillé des failles identifiées.

A. Exploration des pages et des formulaires

L'exploration est réalisée via un crawler (`crawler.py`) qui analyse l'application cible pour identifier les pages accessibles et les formulaires existants.

Exemple :

- Détection d'une page de connexion à *`http://localhost:3000/login`*
- Détection d'un formulaire de mise à jour de profil sur *`http://localhost:3000/profile`*

B. Injection de charges utiles malveillantes

L'outil envoie des payloads (`dast_analyzer.py`) aux formulaires détectés pour tester différentes attaques :

- Injection SQL (SQLi) → *`'OR '1'='1`*
- Cross-Site Scripting (XSS) → *`<script>alert('XSS')</script>`*
- Directory Traversal → *`../../etc/passwd`*

Ces attaques permettent de tester si l'application filtre correctement les entrées utilisateur.

C. Analyse des réponses HTTP

Chaque requête est surveillée pour identifier des indices de vulnérabilité, comme :

- Erreurs SQL indiquant une possible injection SQL.
- Exécution de scripts JavaScript indiquant une faille XSS.
- Lecture de fichiers système prouvant un Directory Traversal.

D. Analyse avancée via OpenAI GPT

Les réponses suspectes sont envoyées à GPT-4 pour une évaluation approfondie.

GPT analyse la réponse et fournit une **explication détaillée** ainsi que des recommandations pour corriger les failles.

E. Resultat

Execution de notre modèle

```
PS E:\Téléchargements\VulScan> python main.py
[INFO] Démarrage du scan de vulnérabilités
[INFO] Exploration de : http://localhost:3000
[INFO] Pages trouvées : 1
[INFO] Formulaires trouvés : 1
[INFO] Test des vulnérabilités sur : http://localhost:3000/login
Payload : ' OR '1'='1'
GPT Analysis : D'après la réponse du serveur, il ne semble pas y avoir d'indices explicites de vulnérabilités SQL Injection, XSS ou Directory Traversal. Le message "Identifiants invalides ou utilisateur non trouvé !" indique simplement une tentative échouée de connexion ou une recherche d'utilisateur.

Cela dit, le payload que vous avez mentionné ' OR '1'='1 est une technique couramment utilisée pour tester les failles d'injection SQL. Si le système est vulnérable, une telle injection pourrait forcer l'application à exécuter des requêtes non prévues. Cependant, la réponse reçue ne fournit pas d'information indiquant que le système est vulnérable à une telle attaque.
```

Rapport JSON

```
{
  "scan_summary": {
    "total_tests": 3,
    "vulnerabilities_found": 0
  },
  "test_results": [
    {
      "url": "http://localhost:3000/login",
      "payload": "' OR '1'='1",
      "status_code": 200,
      "response_text": "Identifiants invalides ou utilisateur non trouvé !",
      "vulnerability": "[OK] Aucune vulnérabilité détectée.",
      "gpt_analysis": "D'après la réponse du serveur, il ne semble pas y avoir d'indices explicites de vulnérabilités SQL Injection, XSS ou Directory Traversal. Le message \"Identifiants invalides ou utilisateur non trouvé !\" indique simplement une tentative échouée de connexion ou une recherche d'utilisateur. \n\nCela dit, le payload que vous avez mentionné ' OR '1'='1 est une technique couramment utilisée pour tester les failles d'injection SQL. Si le système est vulnérable, une telle injection pourrait forcer l'application à exécuter des requêtes non prévues. Cependant, la réponse reçue ne fournit pas d'information indiquant que le système est vulnérable à une telle attaque. \n\nIl est recommandé de continuer à tester avec différents payloads pour différentes vulnérabilités, et, si possible, de mettre en place des outils de détection automatisée pour des vulnérabilités plus sophistiquées.\n\nVeuillez noter que ces analyses de sécurité doivent toujours être effectuées dans un cadre légal, idéalement sur vos propres systèmes ou sur ceux pour lesquels vous avez obtenu une autorisation explicite à tester."
    }
  ],
}
```

VI. L'analyse de réseaux assistée par IA

l'objectif est de fournir une méthode automatisée pour détecter les vulnérabilités réseau, combinant des outils traditionnels comme

avec un service d'analyse assisté par intelligence artificielle, basé sur l'API **OpenAI GPT**. Cette solution offre une approche interactive et détaillée pour l'analyse et la documentation des vulnérabilités, tout en produisant des rapports clairs et exploitables.

A. Fonctionnement Technique

La solution repose sur les éléments suivants :

- **Scanner Nmap :**
 - Le composant principal pour l'analyse réseau est Nmap, qui exécute des scans détaillés pour collecter des informations sur les ports ouverts, les services en cours d'exécution, et leurs versions.
 - Le scan est effectué avec l'option **-sV** pour détecter les versions des services et obtenir des informations précises sur les hôtes cibles.
- **Extraction des Ports Ouverts :**
 - Les résultats du scan sont analysés pour extraire les informations pertinentes concernant les ports ouverts (TCP/UDP) et les services actifs.
 - Ces données servent de base pour une analyse approfondie.
- **Analyse Assistée par GPT :**
 - Les données obtenues via Nmap sont transmises au modèle GPT-4o d'OpenAI pour effectuer une évaluation des vulnérabilités.
 - Les résultats incluent :
 - Une description des vulnérabilités détectées.
 - L'identification des points affectés (hôte, port, service).
 - Des références vers des standards de sécurité comme **OWASP ASVS**, **WSTG**, **CAPEC**, et **CWE**, avec des liens hypertextes.
- **Rapports au Format HTML :**
 - Les analyses sont exportées sous forme de rapports HTML, permettant une visualisation claire et une utilisation pratique par les équipes de sécurité.

B. Commandes Disponibles

Pour scanner un hôte ou une IP cible, la commande suivante peut être utilisée :

python3 nmapscanner.py -t <Target IP ou Nom de hôte>

Exemple: python3 nmapscanner.py -t 57.129.95.251

C. Résultats

- **Rapport sur le CLI**

```
2. PostgreSQL Database Exposure
Description: The PostgreSQL database is accessible over the network on port 5432. If not properly secured, this can lead to unauthorized access to the database.
Affected Endpoint: Host: 57.129.75.157, Port: 5432, Service: PostgreSQL
Evidence: The scan results indicate that PostgreSQL is running and accessible on port 5432.
References:
OWASP ASVS
OWASP WSTG
CAPEC-309: Exploitation of Privilege/Trust
CWE-284: Improper Access Control

3. Node.js Express Framework Exposure
Description: The Node.js Express framework is running on port 8080. If not properly configured, it may be vulnerable to various attacks such as Cross-Site Scripting (XSS) or SQL Injection.
Affected Endpoint: Host: 57.129.75.157, Port: 8080, Service: HTTP (Node.js Express)
Evidence: The scan results show the service as "Node.js Express framework" on port 8080.
References:
OWASP ASVS
OWASP WSTG
CAPEC-63: Cross-Site Scripting
CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

4. Unknown Service on Port 9000
Description: An unknown service (cslister) is running on port 9000. Without further information, this service could potentially be vulnerable to various attacks.
Affected Endpoint: Host: 57.129.75.157, Port: 9000, Service: cslister
Evidence: The scan results show an open port 9000 with the service name "cslister".
References:
OWASP ASVS
OWASP WSTG
CAPEC-170: Fingerprinting
CWE-200: Information Exposure

...
Results have been exported to 57.129.75.157-20250127-204651.html
```

- **Rapport HTML**

localhost:63342/code-vulnerability-analysis/57.129.75.157-20250127-204651.html?_ijt=84fc1vsk2pu6v5bbpeg590lfp&...
Import bookmarks... Google Agenda Gmail Partage Awesome Software Ar... Operating System Con... Silae RH AIDE MOBILI-JEUNE Other Bookmarks

Vulnerability Report

...html

Vulnerability Analysis Report

1. HTTP Server Information Disclosure

Description: The HTTP server running on ports 80 and 443 discloses its version number (nginx 1.24.0). This information can be used by attackers to identify vulnerabilities specific to this version.

Affected Endpoint: Host: 57.129.75.157, Ports: 80, 443, Service: HTTP

Evidence: The scan results show the HTTP server as "nginx 1.24.0" on both ports 80 and 443.

References:
[OWASP ASVS](#)
[OWASP WSTG](#)
[CAPEC-170: Fingerprinting](#)
[CWE-200: Information Exposure](#)

2. PostgreSQL Database Exposure

Description: The PostgreSQL database is accessible over the network on port 5432. If not properly secured, this can lead to unauthorized access to the database.

Affected Endpoint: Host: 57.129.75.157, Port: 5432, Service: PostgreSQL

Evidence: The scan results indicate that PostgreSQL is running and accessible on port 5432.

References:
[OWASP ASVS](#)
[OWASP WSTG](#)
[CAPEC-309: Exploitation of Privilege/Trust](#)
[CWE-284: Improper Access Control](#)

3. Node.js Express Framework Exposure

Description: The Node.js Express framework is running on port 8080. If not properly configured, it may be vulnerable to various attacks such as Cross-Site Scripting (XSS) or SQL Injection.

Affected Endpoint: Host: 57.129.75.157, Port: 8080, Service: HTTP (Node.js Express)

D. Point Forts et Limites

Avantages :

- Automatisation complète du processus, intégrant des outils standards et une IA avancée.
- Rapports détaillés avec des références vers des standards de sécurité reconnus.

- Analyse interactive et export HTML pour une collaboration efficace.

Limites :

La qualité des résultats dépend de la précision des scans Nmap et des capacités du modèle GPT à interpréter les données.

Les analyses GPT nécessitent une connexion stable à l'API OpenAI.

E. Perspective d'amélioration

- Intégrer des outils complémentaires comme **OpenVAS** ou **Nessus** pour des analyses plus poussées.
- Ajouter un module pour la gestion des résultats historiques et leur comparaison.
- Permettre des scans sur des plages d'adresses IP pour couvrir des infrastructures plus grandes.
- Intégrer dans le pipeline sur Gitlab ou Github

VII. Conclusion

L'intégration de l'intelligence artificielle dans l'analyse des vulnérabilités marque une avancée majeure en cybersécurité, permettant une détection plus rapide, plus précise et mieux contextualisée des failles. Grâce à une approche combinant des outils traditionnels et des modèles d'IA comme GPT, cette solution optimise l'identification des vulnérabilités aussi bien dans le code source que dans les infrastructures réseau. En automatisant l'analyse et en générant des rapports détaillés et exploitables, elle offre un gain de temps considérable aux équipes de développement et de sécurité.

Toutefois, des défis subsistent, notamment en matière de dépendance aux données, de coûts et de complexité technique. Pour aller plus loin, des améliorations peuvent être envisagées, telles que l'intégration d'autres outils de scan, une meilleure gestion des résultats historiques ou encore l'automatisation dans des pipelines DevSecOps. En conclusion, cette approche innovante contribue à renforcer la sécurité des systèmes informatiques face aux menaces toujours plus sophistiquées.